НОРМАТИВНО-ПРАВОВАЯ БАЗА ЕВРОПЕЙСКОГО СОЮЗА (ЕС) В ОБЛАСТИ РЕЗИЛЬЕНТНОСТИ КРИТИЧЕСКИХ ОБЪЕКТОВ

Рубрика: ОРГАНИЗАЦИЯ ЗАЩИТЫ КРИТИЧЕСКИХ ОБЪЕКТОВ

Автор: Ларин А.И. Заместитель главного редактора журнала

Мы продолжаем публикацию статей по защите объектов критической инфраструктуры. Что происходит в этой сфере у наших «друзей» из Европы? Там формируется новая система защиты критической инфраструктуры, построенная не столько на охране отдельных физических объектов, сколько на обеспечении «резильентности»[2] – способности объектов предотвращать сбои, противостоять им, смягчать последствия и быстро восстанавливаться. Основой этой системы стала Директива ЕС 2022/2557 о резильентности критических объектов (Critical Entities Resilience Directive, CER Directive) (далее по тексту – Директива). Летом 2026 года Европейская комиссия дополнила Директиву не обязывающим[3] методическим руководством по конкретным техническим, организационным и физическим мерам защиты. В представленной аналитической статье рассматриваются значение, причины появления, структура, задачи, функции, практика применения и выявленные недостатки этих документов.

Часть I. Директива ЕС 2022/2557 о резильентности критических объектов

1.1. Значение документа

CER Directive – это первый общеевропейский рамочный акт, который переносит акцент политики защиты инфраструктуры с узкой охраны отдельных «европейских критических инфраструктур» (подход Директивы 2008/114/ЕС) на комплексную резильентность организаций как таковых. Директива охватывает 11 секторов: энергетику, транспорт, банковское дело, инфраструктуру финансового рынка, здравоохранение, питьевую воду, сточные воды, цифровую инфраструктуру, публичное управление, космос и производство/переработку/распределение продовольствия. Она заменяет собой Директиву Совета 2008/114/ЕС, которая утратила силу с 18 октября 2024 года, и работает в тесной связке с Директивой ЕС NIS2[4] 2022/2555 о кибербезопасности и Регламентом DORA[5] 2022/2554 об операционной цифровой устойчивости финансового сектора. Вместе эти три акта образуют «пакет резильентности» ЕС, где CER Directive отвечает за физические, организационные и «нецифровые» аспекты, а NIS2 и DORA – за киберустойчивость.

Значение Директивы состоит в том, что она впервые вводит единые минимальные стандарты и требования для определения того, какие организации считаются «критическими», единый набор обязанностей для этих организаций (оценка рисков,

план резильентности, уведомление об инцидентах) и единую институциональную архитектуру (компетентные органы, единые контактные пункты, Группа по резильентности критических объектов на уровне Комиссии ЕС). Тем самым устраняется прежняя фрагментация, при которой одни и те же по типу организации в одних странах ЕС признавались критическими, а в других – нет, и подчинялись разным требованиям.

1.2. Причины разработки Директивы

Директива была принята 14 декабря 2022 года и опубликована в Официальном журнале ЕС 27 декабря 2022 года (OJ L 333, стр. 164–198). К ее разработке подтолкнул ряд факторов, зафиксированных в преамбуле акта:

- пандемия COVID-19 продемонстрировала уязвимость государств-членов ЕС перед рисками с низкой вероятностью, но высоким воздействием, включая разрывы цепочек поставок с каскадным эффектом на несколько секторов и стран одновременно;

- оценка прежней Директивы 2008/114/ЕС, проведенная Комиссией в 2019 году, показала, что защита отдельных физических объектов («европейских критических инфраструктур» в энергетике и на транспорте) недостаточна в условиях растущей взаимозависимости инфраструктур и трансграничного характера операций;

- усилился ландшафт гибридных и террористических угроз, выросли climate-related риски (стихийные бедствия, изменение климата, снижающее срок службы инфраструктуры), а также риск инсайдерских угроз и саботажа;

- различия в национальных требованиях к «критическим» организациям создавали избыточную административную нагрузку для трансграничного бизнеса и препятствовали функционированию внутреннего рынка ЕС;

- геополитический контекст (война в Украине, рост числа диверсий на подводных кабелях и трубопроводах, атаки дронов) ускорил принятие Директивы и последующую разработку июльских 2026 года руководств.

Директива вступила в силу 16 января 2023 года; государства-члены ЕС были обязаны транспонировать[6] ее в национальное законодательство до 17 октября 2024 года, а сами нормы начали применяться с 18 октября 2024 года.

1.3. Структура Директивы

Директива состоит из преамбулы, основного текста, разделенного на главы, и приложения с перечнем секторов. Основные главы:

Глава I. Общие положения: предмет регулирования, сфера действия, определения (в том числе понятий «критический объект», «резильентность», «существенная услуга», «инцидент»).

Глава II. Национальные рамки резильентности критических объектов: стратегия государства-члена по повышению резильентности, оценка рисков государством-членом, идентификация критических объектов, поддержка со стороны государств-членов ЕС.

Глава III. Оценка рисков и соблюдение требований критическими объектами: оценка риска критическим объектом (не реже одного раза в 4 года), меры резильентности, план резильентности, назначение ответственного по связям, проверки биографических данных персонала, уведомление об инцидентах – с первичным уведомлением не позднее 24 часов и подробным отчетом не позднее одного месяца.

Глава IV. Сотрудничество и отчетность: Группа по резильентности критических объектов, единые контактные пункты, поддержка со стороны Комиссии, консультативные миссии для «критических объектов особой европейской значимости».

Глава V. Надзор и правоприменение: полномочия компетентных органов на проведение проверок и аудитов, санкции за нарушения – «эффективные, соразмерные и сдерживающие».

Глава VI. Заключительные положения: делегированные и имплементирующие акты, пересмотр Директивы, сроки транспонирования, отмена Директивы 2008/114/ЕС.

Приложение: перечень из 11 секторов и подсекторов, подпадающих под действие Директивы.

Директиву дополняет регламент Комиссии ЕС 2023/2450 от 25 июля 2023 года, устанавливающий неисчерпывающий перечень существенных услуг по секторам и подсекторам, который используется компетентными органами при оценке рисков и идентификации критических объектов.

1.4. Задачи Директивы

Ключевые задачи Директивы:

- обеспечить последовательную гармонизированную идентификацию критических объектов во всех государствах-членах ЕС на основе единых критериев значимости нарушения (число затронутых пользователей, географический охват, длительность сбоя, трансграничные эффекты, рыночная доля, зависимость других секторов);

- повысить способность критических объектов предотвращать, защищаться, реагировать, противостоять, смягчать, поглощать, адаптироваться и восстанавливаться после инцидентов любой природы – природных, техногенных, случайных или умышленных;

- улучшить трансграничное сотрудничество компетентных органов государств-членов ЕС и создать механизмы обмена информацией на уровне ЕС;

- снизить административную нагрузку на организации за счет избежания дублирования с секторальными актами (NIS2, DORA, авиационная и морская безопасность и др.), когда эквивалентные требования уже установлены;

- создать механизм оперативного уведомления об инцидентах для формирования у компетентных органов полной картины сбоев.

1.5. Функции Директивы

Директива выполняет несколько функций одновременно:

- регуляторную (устанавливает минимальные обязательные требования, которые государства-члены ЕС обязаны имплементировать в национальное право);

- координационную (создает институты – Группу по резильентности критических объектов, сеть единых контактных пунктов);

- контрольно-надзорную (наделяет национальные органы полномочиями по инспекциям и санкциям);

- методическую (поручает Комиссии разработку не обязывающих руководств, что впоследствии было реализовано в виде июльского документа 2026 года).

1.6. Особенности применения Директивы на практике

Механизм применения Директивы многоуровневый.

На уровне ЕС Комиссия готовит обзоры трансграничных и межсекторальных рисков, разрабатывает лучшие практики и (как показано ниже) не обязывающие руководства, а также организует консультативные миссии.

На уровне государств-членов ЕС компетентные органы принимают национальную стратегию резильентности, проводят периодическую оценку рисков, идентифицируют критические объекты, уведомляют их и осуществляют надзор (плановые и внеплановые проверки, аудиты, требования по устранению нарушений, штрафы).

На уровне критических объектов происходит собственная оценка рисков (не реже одного раза в 4 года), разработка и практическая реализация плана резильентности, обучение персонала, проверка биографических данных сотрудников, занимающих чувствительные должности, и оперативное информирование регулятора об инцидентах.

Директива выстроена по логике «взаимного зачета» с секторальным регулированием: если объект уже подчиняется эквивалентным требованиям по другому акту ЕС (например, NIS2 для цифровой инфраструктуры, DORA – для финансового сектора, авиационные и морские регламенты безопасности), то

соответствующие статьи Директивы к нему не применяются во избежание дублирования.

К октябрю 2024 года большинство государств-членов ЕС должны были принять национальные законы о транспонировании. В Германии, например, эта функция реализуется через закон KRITIS-Dachgesetz (принят 11 марта 2026 года), в Ирландии – через European Union (Resilience of Critical Entities) Regulations 2024 (S.I. No. 559/2024), вступившие в силу 17 октября 2024 года.

Компетентные органы (в энергетике, на транспорте, в здравоохранении и других секторах) проводят национальные оценки рисков и на их основе формируют перечни критических объектов – операторов электросетей, аэропортов, портов, крупных водоканалов, госпиталей, логистических организаций по доставке продовольствия и др.

Критические объекты, выявленные как таковые, обязаны в течение 10 месяцев после уведомления разработать план резильентности, назначить ответственного по связям и наладить процедуру уведомления об инцидентах в 24-часовой срок.

Компания, оказывающая существенные услуги в шести и более государствах-членах ЕС (например, крупный трансъевропейский оператор газотранспортной или электросетевой инфраструктуры), может стать объектом «консультативной миссии» Комиссии ЕС – с оценкой состояния резильентности силами экспертов ЕС и государств-членов ЕС.

1.7. Выявленные недостатки и проблемы применения Директивы

К середине 2026 года практика выявила ряд системных сложностей применения Директивы:

- задержки транспонирования. Несмотря на срок 17 октября 2024 года, значительная часть государств-членов ЕС вряд ли успеет своевременно принять национальное законодательство. По состоянию на 2026 год Европейская комиссия инициировала передачу дел в Суд ЕС в отношении Болгарии, Испании, Франции, Люксембурга, Нидерландов, Польши и Швеции за неполное или несвоевременное исполнение требований Директивы. Нидерланды, в частности, столкнулись с риском штрафа за пропуск срока защиты жизненно важных секторов от гибридных угроз;

- сжатые сроки для критических объектов. Между идентификацией объекта как критического (до 17 июля 2026 года) и вступлением в силу требований по резильентности проходит всего около 10 месяцев – период, который эксперты (в частности, аналитики Deloitte[7]) называют «амбициозным» и труднодостижимым для организаций без заранее выстроенной системы управления рисками;

- отсутствие единой методологии оценки рисков. Директива задает рамку, но конкретные методики оценки Member State risk assessment и critical entity risk

assessment разрабатываются на национальном уровне, что до появления детализированных руководств Комиссии приводило к разночтениям в подходах между странами;

- мягкий («не обязывающий») характер технических требований. Директива в статье 13(5) прямо предусматривает лишь не обязывающие руководства Комиссии по конкретным техническим и организационным мерам, из-за чего до июля 2026 года у организаций не было детализированного стандарта того, какие именно физические и организационные меры считаются «надлежащими и соразмерными»;

- пересечения и нестыковки с NIS2 и национальными законами. Например, немецкий KRITIS-Dachgesetz покрывает требования CER Directive не полностью – в нем слабее проработаны вопросы контроля доступа, инвентаризации запасов и цепочек поставок, а такие темы, как защита от дронов и вопросы водоснабжения, изначально практически не были отражены ни в Директиве, ни в ее национальной имплементации;

- административная нагрузка на малые и средние предприятия (МСП), оказывающие существенные услуги, несмотря на декларируемый в Директиве принцип поддержки МСП со стороны государств-членов ЕС.

Часть II. Методическое руководство Еврокомиссии от июля 2026 года по техническим и организационным мерам защиты критической инфраструктуры

2.1. Значение Руководства

10 июля 2026 года Европейская комиссия приняла Коммюнике, содержащее не обязывающее руководство для государств-членов ЕС и критических объектов по техническим, организационным и мерам безопасности для укрепления резильентности критической инфраструктуры перед лицом природных и антропогенных рисков. Формальное наименование – «Guidelines on the application of Article 13(5) of Directive (EU) 2022/2557 on the resilience of critical entities» (далее по тексту – Руководство). Документ опубликован 13 июля 2026 года.

Повторим, что Руководство имеет не обязывающий статус, что означает, что он не создает дополнительных юридических обязательств сверх изложенных в Директиве, а служит только инструментом толкования и практической реализации положений Директивы.

Значение Руководства в том, что оно впервые с момента принятия Директивы 2022 года переводит общие, рамочные обязанности (превентивные меры, физическая защита, реагирование и смягчение последствий, восстановление, обеспечение безопасности персонала) в конкретный, детализированный и структурированный набор из 94 мер и рекомендаций, распределенных по семи тематическим блокам. Тем самым документ закрывает главный пробел Директивы – отсутствие единого технического стандарта резильентности – и одновременно синхронизируется по

срокам с обязанностью государств-членов ЕС идентифицировать критические объекты до 17 июля 2026 года, обеспечивая заинтересованных лиц ориентиром накануне вступления в силу их индивидуальных обязательств.

2.2. Причины разработки Руководства

Руководство было разработано в соответствии с пунктом 29 преамбулы и статьей 13 Директивы (ЕС) 2022/2557, которыми предусмотрено, что Комиссия после консультаций с Группой по резильентности критических объектов принимает не обязывающие руководства, конкретизирующие технические, охранные и организационные меры. Разработка велась Комиссией совместно с CER DirectiveG в течение 2025 года и сопровождалась широкими консультациями с заинтересованными сторонами – государствами-членами, европейскими отраслевыми ассоциациями секторов, охваченных Директивой, и в тесном взаимодействии с международными партнерскими организациями.

Непосредственными причинами выпуска документа именно в июле 2026 года стали:

- приближение ключевого срока 17 июля 2026 года, к которому государства-члены ЕС обязаны определить конкретные критические объекты – исполнителям нужен ориентир по мерам еще до начала действия их индивидуальных требований резильентности;

- рост актуальности новых типов угроз, не детализированных изначально в тексте Директивы 2022 года: атаки и разведывательная деятельность с использованием беспилотных летательных аппаратов (БПЛА/дронов), гибридные угрозы, саботаж подводной и наземной инфраструктуры;

- документ прямо обозначен как ключевое действие в рамках Плана действий ЕС по безопасности от дронов и противодействию дронам, а также связан со Стратегией внутренней безопасности ЕС, которая подчеркивает важность своевременной и корректной транспозиции Директивы всеми странами ЕС;

- необходимость гармонизации подходов на фоне того, что часть государств-членов ЕС (например, Германия через KRITIS-Dachgesetz) уже приняли собственные детализированные национальные требования, и Комиссии требовалось задать общеевропейский ориентир, сопоставимый с международными стандартами (ISO 27001:2022, ISO 22301:2019).

2.3. Структура Руководства

Руководство содержит семь тематических разделов (A–G), включающих в совокупности 94 конкретные меры, требования и контрольные позиции:

1. Раздел A. Общие положения – управление и риск-менеджмент (позиции A.6–A.17): принципы соразмерности и адекватности мер, охват всех секторов CER Directive, использование результатов национальных и собственных оценок риска, назначение

ответственного по связям, учет взаимозависимостей активов, применение международных стандартов, особое внимание к морской критической инфраструктуре.

2. Раздел B. Превентивные меры (B.18–B.23): интегрированная система управления непрерывностью деятельности, меры снижения риска и климатической адаптации, ведение базы данных инцидентов, выявление задач, подверженных человеческой ошибке, учет требований NIS2, положения о ручном управлении оперативно-технологическими системами (OT) в аварийных ситуациях.

3. Раздел C. Физическая защита и безопасность (C.24–C.50) – самый объемный блок: меры по обнаружению, сдерживанию, задержке и недопущению угроз; периметровая защита (ограждения, барьеры, освещение); контролируемые пропускные пункты; охрана внешних точек входа; системы видеонаблюдения и периметрового мониторинга; многослойные зоны безопасности; защита помещений с инженерными коммуникациями; управление ключами и учетными данными; принцип минимально необходимого доступа; классификация и защита чувствительной информации. Отдельный подраздел (C.46–C.50) посвящен обнаружению и противодействию беспилотным летательным аппаратам – радиолокационное, радиочастотное, тепловизионное обнаружение дронов, контрмеры против разведки и саботажа, партнерство с органами правопорядка и обороны.

4. Раздел D. Реагирование, противостояние и смягчение последствий (D.51–D.65): управление кризисами, резервные источники питания (ИБП и генераторы, топливный запас минимум на 72 часа), альтернативное водоснабжение, запасы критических материалов, программы обслуживания и предиктивного мониторинга, структура управления резильентностью на уровне высшего руководства, протоколы кризисной коммуникации, системы оповещения с геотаргетингом.

5. Раздел E. Восстановление (E.66–E.75): резервирование систем, альтернативные площадки восстановления, планы обеспечения непрерывности бизнеса и анализ воздействия на бизнес, процедуры разбора инцидентов после реагирования, стратегии резильентности цепочек поставок, стратегические запасы, соглашения о совместном использовании ресурсов между организациями секторов.

6. Раздел F. Управление безопасностью персонала (F.76–F.85): выявление категорий персонала с критическими функциями, процедуры предоставления и отзыва доступа, ролевой доступ по принципу «необходимого знания», проверки биографических данных с учетом требований NIS2 и регламента (ЕС) 2024/2690[8], квалификационные требования и соответствующее обучение персонала.

7. Раздел G. Осведомленность (G.86–G.94): программы повышения осведомленности персонала, формирование культуры резильентности, обучение с учетом гендерной чувствительности, визуальные информационные материалы (флоучарты по

действиям при инцидентах), учения и тренировки (настольные и практические), включая межсекторальные и трансграничные учения.

2.4. Задачи Руководства

Основные задачи Руководства:

- дать критическим объектам практический, детализированный ориентир по выбору «надлежащих и соразмерных» технических, охранных и организационных мер, требуемых статьей 13 Директивы, вместо общих формулировок Директивы;

- обеспечить единообразие подходов государств-членов ЕС и организаций к физической защите критической инфраструктуры – от периметровой безопасности до защиты чувствительной информации;

- включить в регуляторный периметр новые категории угроз, прямо не детализированные в тексте Директивы 2022 года: атаки и разведку с применением дронов, гибридные и антагонистические угрозы, а также инсайдерские риски;

- синхронизировать европейский подход с международными стандартами управления информационной безопасностью и непрерывностью бизнеса (ISO 27001:2022, ISO 22301:2019), облегчив организациям, уже сертифицированным по этим стандартам, выполнение требований CER Directive;

- поддержать реализацию Стратегии ProtectEU[9] и Плана действий по безопасности от дронов, обеспечив практическую основу для противодействия новым видам физических угроз критической инфраструктуре.

Руководство выполняет методическую (конкретизация общих требований Директивы), интеграционную (сведение воедино требований CER Directive, NIS2, национальных законов вроде немецкого KRITIS-Dachgesetz и международных стандартов ISO) и превентивно-технологическую функции (закрытие пробелов по новым угрозам – дронам, гибридным атакам, вопросам водоснабжения). При этом документ сохраняет не обязывающий («мягкое право», soft law) статус: он не создает дополнительных юридических обязательств сверх Директивы, а служит инструментом толкования и практической реализации положений Директивы.

Руководство адресовано двум группам: государствам-членам ЕС, которые опираются на него при разработке национальных норм и методических материалов для критических объектов (в частности, немецкий регулятор уже провел сопоставление руководства с национальным KRITIS-Dachgesetz[10]), и самим критическим объектам, которые используют документ как «чек-лист» из 94 позиций при формировании собственного плана резильентности. Поскольку документ носит не обязывающий характер, формальной обязанности точно следовать каждой из 94 позиций нет. Критические объекты обязаны реализовать меры, соразмерные их собственной оценке риска, а руководство лишь предлагает признанный на уровне ЕС ориентир

того, что считается «надлежащей практикой». Национальные компетентные органы при проведении надзорных проверок (инспекций и аудитов,) могут использовать положения руководства как эталон при оценке достаточности мер, принятых конкретной организацией.

2.5. Примеры применения Руководства

Аэропорт или морской порт, идентифицированный как критический объект, может использовать раздел C (физическая защита) для проектирования многоуровневой системы контроля доступа, видеонаблюдения и периметровой защиты, а также для внедрения технологий обнаружения дронов (радиолокационных и акустических систем) в соответствии с позициями C.46–C.50.

Компания, управляющая энергосетью, при разработке плана резильентности может опереться на раздел D (реагирование) для расчета необходимого объема резервного топлива для дизель-генераторов (минимум на 72 часа автономной работы) согласно позиции D.55.

Крупный водоканал или предприятие пищевой промышленности использует раздел B и E для выстраивания системы предиктивного обслуживания оборудования и формирования стратегических запасов сырья на случай нарушения цепочек поставок.

Компания, уже имеющая сертификацию по ISO 27001:2022[11] и ISO 22301:2019[12], может применить сопоставительные таблицы (маппинг[13]), приведенные в комментариях к руководству, чтобы оценить, какие из существующих у нее контролей информационной безопасности и непрерывности бизнеса уже покрывают требования Директивы, а какие пробелы (в первую очередь по физической и кадровой безопасности) необходимо закрыть дополнительно.

Государственный орган, отвечающий за здравоохранение как критический сектор, может использовать раздел F и G для разработки программ проверки персонала и обучения сотрудников больниц действиям при чрезвычайных ситуациях.

2.6. Выявленные недостатки Руководства

Первые независимые разборы документа (в частности, немецкий портал OpenKRITIS, специализирующийся на сопоставлении регуляторных требований к критической инфраструктуре) указывают на следующие проблемы:

- отсутствие юридической обязательности. Руководство остается не обязывающим документом, то есть критические объекты формально не обязаны выполнять каждую из 94 позиций; это создает риск неравномерного применения между странами и организациями и оставляет пространство для формального, а не содержательного соответствия;

- пересечения и повторы между разделами Руководства. Отмечается, что разделы, судя по всему, готовились разными группами авторов внутри Комиссии и CER DirectiveG, из-за чего вопросы управления непрерывностью бизнеса и кризисного менеджмента, а также контроля доступа, оказались раздроблены и частично продублированы между несколькими разделами (B, D, E и F);

- неполное покрытие национальными законами. Даже наиболее продвинутые национальные акты, такие как немецкий KRITIS-Dachgesetz, покрывают требования руководства не полностью: слабее проработаны вопросы контроля доступа, обслуживания оборудования, запасов и цепочек поставок, а темы защиты от дронов и водоснабжения в национальном законодательстве изначально практически отсутствовали;

- частичное соответствие международным стандартам. Сопоставление с ISO 27001:2022 показывает хорошее покрытие в части информационной безопасности, но заметные пробелы по стратегическому управлению резильентностью и общему кризисному менеджменту; сопоставление с ISO 22301:2019 демонстрирует обратную картину – сильное покрытие вопросов непрерывности бизнеса при почти полном отсутствии требований физической и кадровой безопасности. Это означает, что ни один отдельно взятый международный стандарт не закрывает требования CER Directive-руководства полностью, и организациям нужно комбинировать несколько систем менеджмента;

- позднее издание относительно сроков Директивы. Руководство появилось только в июле 2026 года – спустя почти два года после вступления Директивы в силу (октябрь 2024 года) и одновременно практически с истечением срока идентификации критических объектов (17 июля 2026 года), то есть задействованные организации значительную часть переходного периода были вынуждены разрабатывать меры резильентности без детализированного европейского стандарта;

- риск избыточной детализации и административной нагрузки. Объем в 94 отдельные меры при необходимости документирования каждой из них в плане резильентности организации создает существенную нагрузку, прежде всего для малых и средних организации, отнесенных к критическим объектам.

Заключение

Директива ЕС 2022/2557 и дополняющее ее июльское руководство 2026 года образуют двухуровневую систему: Директива задает обязательные юридические рамки (кто является критическим объектом, какие институты его контролируют, какие сроки должны соблюдаться), а руководство переводит общее требование «принимать надлежащие и соразмерные меры» в конкретный операционный стандарт из 94 позиций по семи направлениям – от управления рисками до защиты от дронов. Вместе эти документы формируют наиболее детализированную на сегодня в ЕС нормативно-методическую базу физической и организационной

резильентности критической инфраструктуры, однако практика их применения в 2024–2026 годах показала типичные для директив ЕС проблемы: задержки соответствующих изменений в национальных законодательствах, сжатые сроки для задействованных организаций, неполную гармонизацию с национальными законами и международными стандартами, а также сохраняющуюся мягкость («не обязывающий» статус) ключевого технического руководства.

Список использованной литературы

1. Directive (EU) 2022/2557 of the European Parliament and of the Council of 14 December 2022 on the resilience of critical entities and repealing Council Directive 2008/114/EC (Text with EEA relevance). – Official Journal of the European Union, OJ L 333, 27.12.2022, pp. 164–198. – EUR-Lex, официальный сайт ЕС.

2. Making critical entities more resilient. Резюме законодательства к Директиве (ЕС) 2022/2557. – EUR-Lex, LEGISSUM:4632724, обновлено 19.02.2024.

3. The Critical Entities Resilience Directive enters into application to ensure the protection of critical infrastructure. – Европейская комиссия, Directorate-General for Migration and Home Affairs (home-affairs.ec.europa.eu), 23.10.2024.

4. Critical infrastructure resilience at EU-level. – Европейская комиссия, Directorate-General for Migration and Home Affairs (home-affairs.ec.europa.eu), обновлено 13.01.2026.

5. Commission issues guidance to strengthen resilience of critical infrastructure. – Европейская комиссия, Directorate-General for Migration and Home Affairs (home-affairs.ec.europa.eu), 10.07.2026.

6. Guidelines on the application of Article 13(5) of Directive (EU) 2022/2557 on the resilience of critical entities. Communication from the Commission, C/2026/4730 (руководящие принципы также обозначены как C/2026/3712), 13.07.2026.

7. Commission Delegated Regulation (EU) 2023/2450 of 25 July 2023 supplementing Directive (EU) 2022/2557 of the European Parliament and of the Council by establishing a list of essential services. – Official Journal of the European Union, OJ L, 2023/2450, 30.10.2023.

8. Critical entities resilience. – Joint Research Centre, Европейская комиссия (joint-research-centre.ec.europa.eu).

9. Navigating the EU Critical Entities Resilience Directive. What public and private sector leaders need to know and need to do. – Deloitte Global (deloitte.com), аналитический обзор.

10. CER Directive-Guidelines for Resilience C/2026/3712 (обзор и сопоставление с ISO 27001:2022, ISO 22301:2019 и немецким законом KRITIS-Dachgesetz). – OpenKRITIS (openkritis.de), версия от 18.07.2026.

11. European Commission Refers to Court of Justice for Failing to Transpose Directive on Critical Entities Resilience. – BTA News Agency (bta.bg).

12. NL facing EU fine for missing deadline to protect vital sectors against hybrid threats. – NL Times (nltimes.nl), 06.05.2026.

13. S.I. No. 559/2024 – European Union (Resilience of Critical Entities) Regulations 2024. – Irish Statute Book (irishstatutebook.ie).

Примечания

2. Резильентность (от англ. resilience – упругость, эластичность, устойчивость) – в нашем случае это устойчивость системы или отдельных объектов, их способность справляться с чрезвычайными ситуациями, а затем восстанавливаться и адаптироваться к ним.

3. Не обязывающий статус руководства («мягкое право», soft law) означает, что данный документ не создает дополнительных юридических обязательств сверх изложенных в Директиве, а служит инструментом толкования и практической реализации положений Директивы. Другими словами, руководство носит только методический и разъясняющий характер и не содержит новых нормативно-правовых требований.

4. NIS2 – набор правил в сфере кибербезопасности, которые Европейский союз ввел для повышения защиты критически важной инфраструктуры. Документ обязывает многие организации в определенных секторах (энергетика, транспорт, здравоохранение, финансы, цифровая инфраструктура, почтовые услуги и другие) принимать более серьезные меры защиты от киберугроз, быстрее сообщать о серьезных инцидентах и нести персональную ответственность за безопасность. За нарушения требований предусмотрены крупные штрафы, размер которых может доходить до нескольких миллионов евро.

5. Регламент DORA (Digital Operational Resilience Act) Европейского союза принят 14 декабря 2022 года. Его главная цель – повысить цифровую операционную устойчивость финансового сектора ЕС, обеспечить способность финансовых организаций противостоять киберугрозам, техническим сбоям и другим операционным рискам, а также быстро восстанавливаться после них. DORA устанавливает единые требования к управлению информационно-коммуникационными технологиями (ИКТ) и сопутствующими рисками для широкого круга организаций. Он затрагивает банки, страховые компании,

инвестиционные фонды, платежные системы, сервисы по работе с криптовалютами и другие субъекты финансового рынка. Также под действие регламента подпадают критически важные сторонние поставщики ИКТ-услуг (например, облачные провайдеры), которые предоставляют услуги организациям ЕС.

6. В законодательстве транспонирование – это процесс переноса правовых норм из одного нормативного акта в другой, причем акт, в который нормы переносятся, как правило, имеет меньшую юридическую силу, чем исходный. Чаще всего термин встречается в контексте интеграции международного или наднационального права в национальное. Например, государства-члены ЕС обязаны транспонировать директивы Европейского союза в свои внутренние законы. Это означает, что они принимают необходимые законы и подзаконные акты, чтобы реализовать положения директивы, и часто обязаны сообщать об этом Европейской комиссии. Суть в том, что нормы, изначально созданные на более высоком уровне (например, в акте ЕС), адаптируются и закрепляются в законодательстве страны. При этом часто требуется не просто дословное копирование, а корректировка текста с учетом особенностей национальной правовой системы.

7. Deloitte (полное юридическое название – Deloitte Touche Tohmatsu Limited, или DTTL) – это международная аудиторско-консалтинговая корпорация, одна из крупнейших в мире профессиональных сетей. Она входит в «большую четверку» аудиторских компаний наряду с PricewaterhouseCoopers, Ernst & Young и KPMG.

8. Регламент (ЕС) 2024/2690 – нормативный акт Европейского союза, принятый для детализации и практического применения Директивы (ЕС) 2022/2555 об управлении рисками в сфере кибербезопасности. Документ опубликован в официальном журнале ЕС 17 октября 2024 года. Основная задача регламента – установить технические и методологические требования к мерам по управлению рисками в сфере кибербезопасности. Он также конкретизирует критерии, по которым инцидент признается значительным, применительно к определенным поставщикам цифровых услуг и инфраструктур.

9. ProtectEU – стратегия внутренней безопасности Европейского союза (ЕС), направленная на усиление защиты населения от современных угроз и повышение устойчивости ЕС.

10. KRITIS-Dachgesetz (официальное название – Gesetz zur Stärkung der physischen Resilienz kritischer Anlagen, сокращенно KRITIS-DachG) – это немецкий «зонтичный» закон, который создает единую правовую базу для защиты критической инфраструктуры. Закон приняли в 2026 году, и он уже вступил в силу (17 марта). Его главная задача – укрепить способность критически важных объектов (энергетика, транспорт, водоснабжение, здравоохранение, IT и телеком, финансы, продовольствие, космос и др.) противостоять разным угрозам: природным катастрофам, техническим сбоям, саботажу, террористическим актам. То есть это не

про кибербезопасность (этим занимается NIS2), а про физическую и организационную устойчивость.

11. ISO/IEC 27001:2022 – это международный стандарт, который устанавливает требования к системе менеджмента информационной безопасности (СМИБ). Предназначен для организации процесса управления рисками в сфере информационной безопасности: от их выявления и оценки до выбора мер защиты и постоянного улучшения.

12. ISO 22301:2019 – международный стандарт, содержащий требования к системе менеджмента непрерывности деятельности (СМНД). Его полное название – «Безопасность и устойчивость. Системы менеджмента непрерывности деятельности. Требования» (Security and resilience – Business continuity management systems – Requirements). Основная цель ISO 22301:2019 – помочь организациям подготовиться к нештатным ситуациям, эффективно на них реагировать и восстанавливать критически важные процессы. Стандарт дает организациям инструмент для повышения устойчивости: помогает заранее выявить угрозы, оценить масштаб их влияния, разработать планы действий и регулярно их тестировать.

13. Маппинг – это процесс установления соответствия между элементами разных структур данных.